VULNERABILITY ASSESSMENT REPORT

HTTP://TESTPHP.VULNWEB.COM

OVERALL RISK LEVELS

3	3	3	2
Critical Risk	High Risk	Medium Risk	Low Risk

NMAP

Basic port & Exposure analysis

NMAP

Commands:

- nmap -Pn testphp.vulnweb.com
- nmap -sV -T4 --open -p 21,22,25,53,80,443,3306,8080,8443 testphp.vulnweb.com
- nmap --script http-sql-injection,http-csrf,http-stored-xss,http-enum testphp.vulnweb.com

```
Microsoft Windows [Version 10.0.19042.572]
(c) 2020 Microsoft Corporation. All rights reserved.

C:\Users\lenovo>nmap --version
Nmap version 7.94 ( https://nmap.org )
Platform: i686-pc-windows-windows
Compiled with: nmap-liblua-5.4.4 openssl-3.0.8 nmap-libssh2-1.10.0 nmap-libz-1.2.13 nmap-libpcre-7.6 Npcap-1.75 nmap-libdnet-1.12 ipv6
Compiled without:
Available nsock engines: iocp poll select
```

```
C:\Users\lenovo>nmap -Pn testphp.vulnweb.com
Starting Nmap 7.94 ( https://nmap.org ) at 2026-04-20 20:11 India Standard Time
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up.
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 205.13 seconds
```

```
C:\Users\lenovo>nmap -Pn -sV -T4 --open -p 21,22,25,53,80,443,3306,8080,8443 testphp.vulnweb.com
Starting Nmap 7.94 ( https://nmap.org ) at 2026-04-20 20:34 India Standard Time
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.93 seconds
```

```
C:\Users\lenovo>nmap -Pn --script http-sql-injection,http-csrf,http-stored-xss,http-enum testphp.vulnweb.com
Starting Nmap 7.94 ( https://nmap.org ) at 2026-04-20 20:47 India Standard Time
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 0 undergoing Host Discovery
Parallel DNS resolution of 1 host. Timing: About 0.00% done
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up.
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
All 1000 scanned ports on testphp.vulnweb.com (44.228.249.3) are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)

Nmap done: 1 IP address (1 host up) scanned in 204.51 seconds
```

Finding ID	Title	Risk	Tool	CVSS
VULN-008	Server and PHP version disclosure via response headers	Medium	Nmap	5.3
VULN-010	No HTTPS — all traffic transmitted in plaintext	Medium	Nmap	5.9

VULN-008 SERVER AND PHP VERSION DISCLOSURE VIA RESPONSE HEADERS

Medium Risk

Tool: Nmap + Browser DevTools
Evidence: Nmap service detection and DevTools Network tab both confirm: Server: nginx/1.19.0 and X-Powered-By: PHP/5.6.40 38+ubuntu20.04.1+deb.sury.org+1.
Remediation: In nginx.conf: server_tokens off; In php.ini: expose_php = Off

VULN-010 NO HTTPS — ALL TRAFFIC TRANSMITTED IN PLAINTEXT

Medium Risk

Tool: Nmap
Evidence: Nmap: 80/tcp open, 443/tcp filtered. No HTTPS redirect.
Remediation: Obtain a TLS certificate (Let's Encrypt is free). Configure nginx to serve HTTPS on port 443.

OWASP ZAP

Identify vulnerabilities

Finding ID	Title	Risk	Tool	CVSS
VULN-001	SQL Injection — multiple parameters	Critical	OWASP	9.8
VULN-002	End-of-life PHP 5.6 — 100+ unpatched CVEs	Critical	OWASP	9.8
VULN-003	Local File Inclusion (LFI) — credentials exposed	Critical	Manual	9.1
VULN-004	Cross-Site Scripting (XSS) — 7+ endpoints	High	OWASP	8.2
VULN-005	No CSRF protection on any forms	High	OWASP	8.1
VULN-006	Server-side template injection (SSTI)	High	OWASP	7.5
VULN-009	All security response headers absent	Medium	OWASP	5.4
VULN-011	PHP error messages displayed to end users	Low	OWASP	3.7
VULN-012	HTML source contains developer comments with internal notes	Low	OWASP	2.6

VULN-001 SQL INJECTION

Critical Risk

9.8

Tool: OWASP ZAP + Manual
Evidence: cat=1 OR 17-7=10 returned product records. Error: 'You have an error in your SQL syntax' returned in page body on injection.
Remediation: Use PDO prepared statements. Set display errors = Off in php.ini to suppress error details.

VULN-002 END-OF-LIFE PHP 5.6 - 100+ UNPATCHED CVES

Critical Risk

9.8

Tool: OWASP ZAP + Nmap
Evidence: HTTP response header: X-Powered-By: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1
Remediation: Upgrade to PHP 8.2 or later immediately.

VULN-003 LOCAL FILE INCLUSION (LFI)

Critical Risk

9.1

Tool: OWASP ZAP + Manual
Evidence: Credentials acuart:trustno1 confirmed readable from server configuration file.
Remediation: Validate all file path inputs against a strict whitelist of allowed files.

VULN-004 CROSS-SITE SCRIPTING (XSS)

High Risk

Tool: OWASP ZAP + Manual
Evidence: ZAP injected <ScRiPt>alert(1)</ScRiPt> — confirmed execution.
Remediation: Encode all user output with htmlspecialchars($val, ENT_QUOTES, 'UTF-8') before inserting into HTML context.

VULN-005 NO CSRF PROTECTION ON ANY FORMS

High Risk

Tool: OWASP ZAP
Evidence: ZAP passive scan confirmed: no CSRF tokens in any form fields.
Remediation: Generate a cryptographically random token per session using random_bytes(32).

VULN-006 SERVER-SIDE TEMPLATE INJECTION (SSTI)

High Risk

Tool: OWASP ZAP
Evidence: ZAP alert: template injection payload triggered expression evaluation in server response.
Remediation: Never pass user input as a template string. Always pass user data as template context variables.

VULN-009 ALL SECURITY RESPONSE HEADERS ABSENT

Medium Risk

Tool: OWASP ZAP + Browser DevTools
Evidence: Browser DevTools Network tab confirms all six headers absent. Securityheaders.com grade: F.
Remediation: Add in nginx server block: add_header Strict-Transport-Security 'max-age=31536000;

VULN-011 PHP ERROR MESSAGES DISPLAYED TO END USERS

Low Risk

Tool: OWASP ZAP
Evidence: ZAP confirmed: raw MySQL error message 'You have an error in your SQL syntax' returned in page body.
Remediation: In php.ini: display_errors = Off, log_errors = On, error_log = /var/log/php_errors.log.

VULN-012 HTML SOURCE CONTAINS DEVELOPER COMMENTS WITH INTERNAL NOTES

Low Risk

Tool: OWASP ZAP
Evidence: OWASP ZAP passive scan alert: suspicious comments detected in HTML source.
Remediation: Audit and remove all HTML comments from production templates.

BROWSER DEVTOOLS

Inspect headers, cookies, and client-side issues

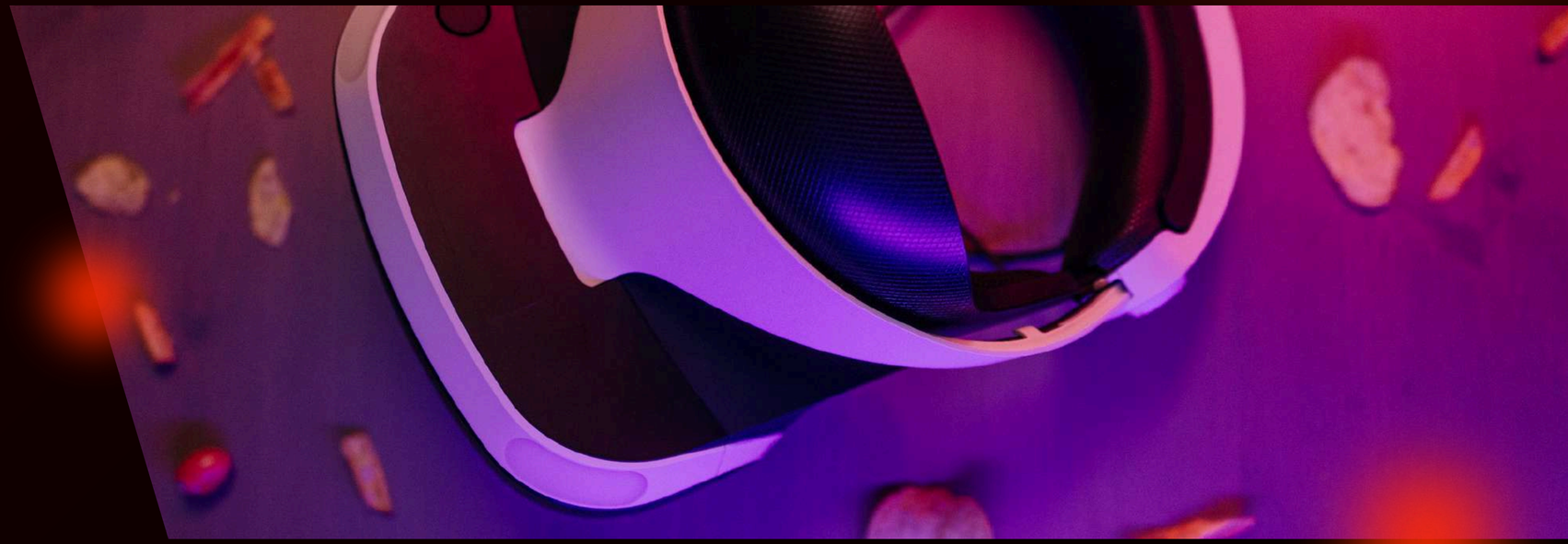
Finding ID	Title	Risk	Tool	CVSS
VULN-007	Session cookie missing Secure and HttpOnly flags	High	Browser	7.4

VULN-007 SESSION COOKIE MISSING SECURE AND HTTPONLY FLAGS

High Risk

Tool: Browser DevTools
Evidence: Observed in DevTools Application > Cookies: login=test/test, no Secure flag, no HttpOnly flag, no SameSite attribute.
Remediation: Set cookie flags: setcookie('session', $token, ['httponly'=>true, 'secure'=>true, 'samesite'=>'Strict']).

CONCLUSION



The assessment of testphp.vulnweb.com identified 12 vulnerabilities including 3 Critical, 3 High, 3 Medium, and 2 Low severity findings. The three critical vulnerabilities — SQL Injection, Local File Inclusion, and end-of-life PHP 5.6 — collectively present a complete path to full database and server compromise. Immediate remediation of these findings is strongly recommended.

THANK YOU